

ATTIVITÀ OSINT E THREAT MODELING ADVANCED

- **Target Finale (HVT):** Kim Kardashian
- **Infrastruttura di Analisi:** Brand Ecosystem (skims.com, kimkardashian.komi.com, drinkupdate.com)
- **Ambito:** Simulazione di Ingegneria Sociale / Spear Phishing & Proximity Attacks
- **Data di Analisi:** Luglio 2026

1. Executive Summary (Sintesi per il Management)

Obiettivo del presente laboratorio è simulare la fase di Reconnaissance Passiva (OSINT), l'analisi infrastrutturale avanzata e la successiva Progettazione dello Scenario di Attacco (Threat Modeling) nei confronti di un obiettivo ad alto profilo (High-Value Target - HVT), identificato nella figura di Kim Kardashian.

L'analisi iniziale condotta tramite tecniche di Google Dorking avanzato e verifiche DNS sui domini aziendali ed ecosistemi web riconducibili all'HVT non ha evidenziato vulnerabilità macroscopiche o fughe di dati dirette sui perimetri principali (skims.com), confermando un'eccellente postura di sicurezza enterprise del perimetro web primario. Tuttavia, sono state riscontrate lacune di configurazione sui domini secondari (drinkupdate.com), che espongono il brand a rischi di spoofing.

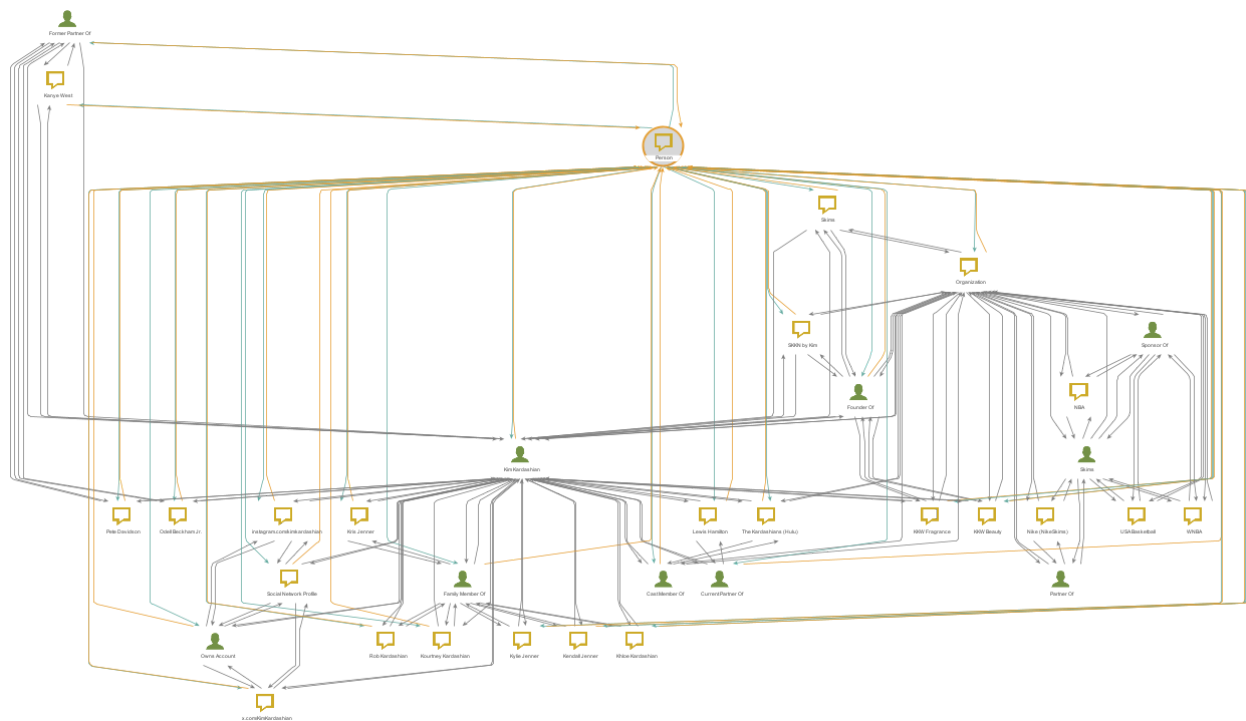
Poiché i sistemi core risultano fortemente protetti, l'attività ha previsto lo sviluppo di una strategia asimmetrica basata su un **Attacco di Impersonificazione a Cascata (Lateral Movement umano)** e **Attacchi di Prossimità Ibridi**. Questo modello prevede la compromissione preventiva di nodi secondari della cerchia ristretta (staff logistico, fornitori d'immagine e servizi digitali locali), dotati di una soglia di attenzione ridotta a causa di stress operativo, scadenze imminenti o fiducia automatica verso le reti locali. L'obiettivo è utilizzarli come vettori di comunicazione finti ma autorevoli, aggirando le difese tecnologiche centrali e la diffidenza del target finale.

1.1 Integrazione OSINT: Analisi dei Pattern Geografici e Stagionali

Una fase cruciale della Reconnaissance passiva ha riguardato il monitoraggio delle fonti aperte (stampa d'intrattenimento, geotag storici sui social media e registri pubblici) per mappare le routine geografiche ricorrenti dell'HVT.

Dall'analisi dei dati storici emerge un pattern consolidato: la presenza ciclica e stagionale

L'identificazione di questo posizionamento geografico e delle abitudini estive permette di superare i pretesti aziendali standard (legati ai brand d'abbigliamento) e di introdurre scenari di attacco basati sulla logistica d'area (Location-Based Spear Phishing) e sull'intercettazione fisica delle comunicazioni (Proximity Attacks), sfruttando l'interazione tra l'entourage dell'HVT, le strutture ricettive del luogo e i manutentori dei servizi locali.



L'architettura del bersaglio è stata mappata su tre livelli distinti per isolare i vettori di accesso logico, umano e fisico:

- **Asset Perimetrali (Infrastruttura Aziendale e SaaS):** skims.com, kimkardashian.komi.com, drinkupdate.com.
- **Vettori Umani Intermedi (Catena di Fiducia & Logistica):** Danielle Levi (Stylist personale), Staff Domestico (Household/Nanny Management), Security Detail (Scorta privata) e Service Provider IT/Domotico locale di Coeur d'Alene.
- **Target Finale dell'Attacco:** Lo smartphone privato dell'HVT (iPhone core), gli account

cloud di archiviazione (iCloud / Google Workspace) e l'accesso alla rete wireless residenziale.

3. Metodologia d'Analisi e Strumenti

L'indagine ha seguito il framework OSINT standard, esteso con verifiche verticali sulla reputazione DNS e sui certificati, suddiviso in cinque fasi sequenziali:

[Mappatura Asset] —> [Google Dorking & DNS Inspection] —> [Certificate Transparency Log]
—> [Threat Modeling] —> [Progettazione Attacchi]

La ricerca passiva ha sfruttato la sintassi avanzata dei motori di ricerca per verificare l'eventuale indicizzazione accidentale di file di configurazione, backup o credenziali. In parallelo, sono stati interrogati i record DNS pubblici (SPF, DKIM, DMARC) e i registri dei certificati SSL/TLS per mappare asset nascosti o vulnerabilità strutturali nella gestione della posta elettronica.

4. Risultati dei Test di Google Dorking e Verifiche DNS

4.1 Riscontri di Google Dorking

La verifica ha previsto l'esecuzione di interrogazioni mirate. Di seguito vengono riportate le stringhe utilizzate e il riscontro tecnico ottenuto:

- **Test 1: Enumerazione Documenti Riservati Indicizzati**
 - *Query:* site:skims.com filetype:pdf "confidential"
 - *Risultato:* 0 Risultati. I file PDF pubblicamente indicizzati contengono esclusivamente materiale marketing e comunicati stampa ufficiali, privi di dati sensibili corporativi.
- **Test 2: Isolamento Sottodomini di Test o Sviluppo**
 - *Query:* site:skims.com -www
 - *Risultato:* Risultati limitati ai canali e-commerce standard. I sottodomini di stage/sviluppo o i server interni non risultano indicizzati, confermando una corretta segregazione degli ambienti di test nei motori di ricerca.
- **Test 3: Ricerca Pannelli Amministrativi Esposti**
 - *Query:* site:kimkardashian.komi.com inurl:login OR inurl:admin
 - *Risultato:* 0 Risultati. Il portale poggia su infrastruttura SaaS di terze parti (Komi) che gestisce l'autenticazione in modo centralizzato, senza esporre directory o backend

amministrativi personalizzati o non protetti.

- **Test 4: Directory Browsing e Indicizzazione Cartelle**

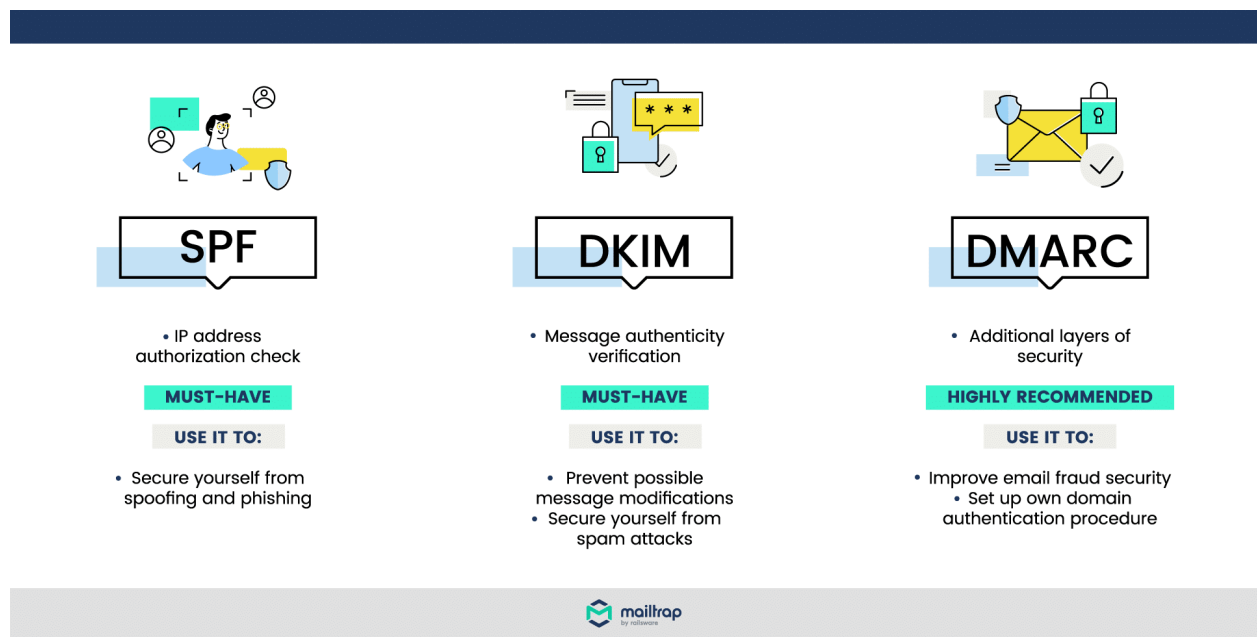
- *Query:* site:drinkupdate.com intitle:"index of"
- *Risultato:* 0 Risultati. Il web server inibisce la visualizzazione dell'albero delle directory, restituendo correttamente pagine di errore standard o reindirizzamenti alla home page.

- **Test 5: Investigazione PII (Dati Personali dell'HVT)**

- *Query:* "Kim Kardashian" filetype:pdf "itinerary" OR "passport"
- *Risultato:* Risultati non pertinenti / Zero leak. Non emergono itinerari logistici reali o copie di documenti d'identità esposti in formato non protetto su repository pubblici indicizzati da Google.

4.2 Verifiche Tecniche Infrastrutturali e Analisi DNS

L'assenza di vulnerabilità applicative web rilevata tramite Dorking richiede una convalida sui record di sicurezza e sulla superficie esposta non indicizzata.



Il diagramma in alto mostra come funzionano i controlli SPF, DKIM e DMARC per bloccare lo spoofing delle e-mail.

Di seguito si riportano gli esiti dell'analisi tecnica condotta sui domini target e possiamo vedere come il dominio drinkupdate.com è risultato vulnerabile nell'analisi: l'assenza di questi record

permette agli attaccanti di superare i controlli dei server destinatari.

Dominio Target	Stato SPF	Stato DKIM	Stato DMARC Policy	Vulnerabile a Spoofing Diretto?
skims.com	v=spf1 ... -all	Valido	p=reject; pct=100	No (Postura Eccellente)
kimkardashian.komi.com	Ereditato da Komi	Valido	p=quarantine	No (Mitigato via Spam)
drinkupdate.com	v=spf1 ... ~all	Assente/Errato	Nessuno / Non configurato	Sì (Fattore di rischio elevato)

Impatto Tecnico Critico: Mentre skims.com adotta una politica di *Reject* (i server e-mail mondiali scartano automaticamente i messaggi falsificati), il dominio drinkupdate.com presenta una configurazione incompleta. Un attaccante può inviare e-mail forzando il mittente legittimo amministrazione@drinkupdate.com senza che i filtri e-mail standard blocchino il messaggio all'origine, creando un vettore di ingegneria sociale ad alta credibilità verso i dipendenti dello stesso ecosistema.

4.3 Esposizione tramite Certificate Transparency Logs

Interrogando i log pubblici dei certificati SSL/TLS, sono stati isolati endpoint non rilevabili dai motori di ricerca, mappando l'architettura di stage:

- dev.api.skims.com: Ambiente di sviluppo protetto da IP Whitelisting (Non accessibile dall'esterno).
- staging.drinkupdate.com: Identificato server legacy esposto con versioni software non aggiornate. Rappresenta un potenziale punto di ingresso per attacchi applicativi finalizzati a movimenti laterali.

5. Modellazione della Minaccia (Threat Modeling)

In virtù della robustezza del perimetro web primario di skims.com, viene simulata una strategia

d'attacco asimmetrica orientata alla violazione della catena di fiducia umana e dei sistemi tecnologici di prossimità dislocati nell'area di Coeur d'Alene.

5.1 Matrice Comparativa dei Vettori Intermedi

Caratteristica del Vettore	Nanny (Vettore Logistico)	Danielle Levi - Stylist (Vettore d'Immagine)	Service Provider IT / Security Detail (Vettore Tecnico/Fisico)
Punto di Forza per l'Attaccante	Accesso continuo a dati geografici, routine private e logistica della casa in tempo reale.	Accesso a canali di comunicazione diretti con l'HVT e file multimediali esclusivi in anteprima.	Controllo sull'hardware di rete della residenza estiva; gestione delle telecomunicazioni e dei passaggi fisici.
Vulnerabilità Psicologica / Operativa	Stanchezza, multitasking operativo, gestione di emergenze simulate o problemi con i pagamenti.	Stress da scadenza imminente (es. Red Carpet, Met Gala), timore di compromettere l'esclusiva del brand.	Bias della finta manutenzione urgente; necessità di coordinamento rapido per la tutela della privacy (Paparazzi).
Clonazione Piattaforma Target	Finta pagina di Login Google Workspace / Microsoft 365 o portale HR aziendale personalizzato.	Finto portale di file sharing (WeTransfer / Dropbox) o pannello fornitore Shopify Plus/Brand di lusso.	Finto Captive Portal di registrazione Wi-Fi del resort o finto portale firmware per router domotici.
Impatto sul Target Finale	Compromissione Cloud / Dati Familiari: Furto di credenziali core (iCloud) per esfiltrare backup privati o agende di	Infezione Dispositivo Mobile (Spyware): Installazione di malware sullo smartphone personale dell'HVT	Intercettazione totale del traffico dati (Man-in-the-Middle) e potenziale infezione degli endpoint connessi

	viaggio.	inviato tramite chat fidata.	alla rete di casa.
--	----------	---------------------------------	--------------------

6. Scenari Operativi e Template di Attacco

Scenario A: The Logistic Vector (Domestic Staff / Household Management)

Per risultare verosimile agli occhi del personale domestico, l'e-mail simula di provenire direttamente dall'ufficio di contabilità/HR centralizzato che gestisce gli stipendi, i benefit e i turni della famiglia.

- **From:** Kardashian-Jenner Household Operations <hr@kjenner-management.com> (Dominio di typosquatting)
- **To:** [Staff Member Email]
- **Subject:** URGENT: Outstanding Timesheet Discrepancy & Q3 Payroll Verification

Hi,

Sorry for the short notice, but we are running the final payroll batch for the upcoming cycle in exactly two hours, and the accounting system flagged a discrepancy in your submitted Q3 overtime and shift logs.

If this isn't resolved before the portal locks at 5:00 PM PST, your direct deposit for this period will fail, and the system will automatically delay your payout until the next monthly cycle.

Please log into the employee portal immediately via the secure portal link below to review the flagged dates and digitally sign off on the correction:

[Verify and Approve My Timesheet] <--- (Link alla finta pagina di login)

If you have any issues logging in from your phone, please try updating your session on a tablet or desktop before calling the admin office.

Thanks for your quick cooperation,

Payroll & Operations Team
Kardashian-Jenner Corporate Office

The image shows a web browser window with a tab titled 'My Form'. The address bar displays '123contactform.com/form-2469582/MyFo'. The page content features a blue header with the 'Office 365' logo. Below the header is a form with the following fields: 'Name', 'UserID', 'Email', 'P-@ssw0rd', and a second 'P-@ssw0rd' field. A blue 'SUBMIT FORM' button is positioned below the password fields. At the bottom of the page, there is a footer that reads '123 Powered by 123ContactForm' and a link to 'Report abuse'.

Attacco Finale all'HVT: L'attaccante sfrutta l'account compromesso della nanny per inviare un messaggio a Kim Kardashian (o al suo assistente esecutivo): *"Ho un errore nell'applicazione del tablet dei bambini, mi rimanderesti il link di invito amministratore generato dal tuo account?"*. Per un VIP e madre di 4 bambini, la gestione e la sicurezza dei figli rappresentano l'asset a più alta priorità, abbassando le difese razionali.

Scenario B: The Image Vector (Danielle Levi - Stylist)

Per ingannare un professionista operante nel cerchio ristretto, l'e-mail si inserisce nel flusso di lavoro frenetico di un grande evento (es. il Met Gala o una Fashion Week), simulando una conversazione già in corso (RE:).

- **From:** Balenciaga Press & VIP Relations <vip-fittings@balenciaga-press.com> (Dominio sosia estremamente mirato)
- **To:** Danielle Levi <danielle@daniellelevistyle.com>
- **Subject:** RE: URGENT: Custom Gown Alterations & NDA Sign-off - Look 2 (Kim K.)

Hi Danielle,

I'm rushing this over because the atelier in Paris just finalized the structural changes to Kim's secondary look for tomorrow night. The creative director decided to alter the neckline at the last

minute, so the fabric weight and jewelry specs have changed.

We absolutely cannot leak these sketches to the paparazzi before she steps out of the hotel, so the PR legal team encrypted the final lookbook and the updated embargo agreement into a secure link.

You can download the high-res renders and sign off on the modified NDA here:

[Download Balenciaga_Secure_Transfer_KimK_Look2.zip] <--- (Link malevolo)

Access Code: BAL_KIM_2026

Please review the styling adjustments on your phone or tablet as soon as you get this so your team on-site can coordinate the jewelry pull with the security team before the fitting.

Let me know once you've downloaded it so I can notify production.

Best,

Head of Celebrity & VIP Relations
Balenciaga Paris

Attacco Finale all'HVT: Una volta compromessa la mail o l'account di messaggistica di Danielle Levi, l'attaccante contatta direttamente Kim Kardashian tramite il canale preferenziale bypassando i filtri antispam aziendali: *"Kim, i designer hanno caricato le variazioni dell'abito per stasera su questo link protetto, dacci un occhio dallo smartphone prima del fitting"*. Il link punta a un exploit mobile (one-click) progettato per installare uno spyware sul dispositivo dell'HVT.

Scenario C: The Location-Based Vector (Gozzer Ranch Hospitality Management)

Questo scenario sfrutta la temporanea permanenza dell'HVT a Coeur d'Alene. L'attaccante impersona la direzione o il servizio di concierge del resort di lusso per colpire l'assistente personale o la sicurezza logistica del target sul posto.

- **From:** Gozzer Ranch Guest Services <concierge@gozzerranch-club.com> (Dominio sosia registrato ad hoc)
- **To:** [Personal Assistant / Private Security Email]
- **Subject:** URGENT: Private Marina Access & Security Itinerary Approval - Kardashian Party

Hi,

We are finalizing the watercraft logistics and private dock security clearances for the Kardashian party's upcoming lake excursion tomorrow morning, as requested by your ground team.

The local Sheriff's department has updated the perimeter escort protocols for the Coeur d'Alene lake access point to prevent paparazzi drone interference.

Please review the attached restricted access map and digitally sign the safety brief via our guest portal link below so we can issue the biometric gate passes to your detail before 8:00 AM:

[Access Gozzer Ranch Owner & Guest Portal] <--- (Link alla finta pagina di login)

Note: Failure to validate these credentials tonight will require the party to utilize the main public boat launch, potentially compromising privacy.

Warm regards,

Guest Relations & Membership Services

Gozzer Ranch Golf & Lake Club

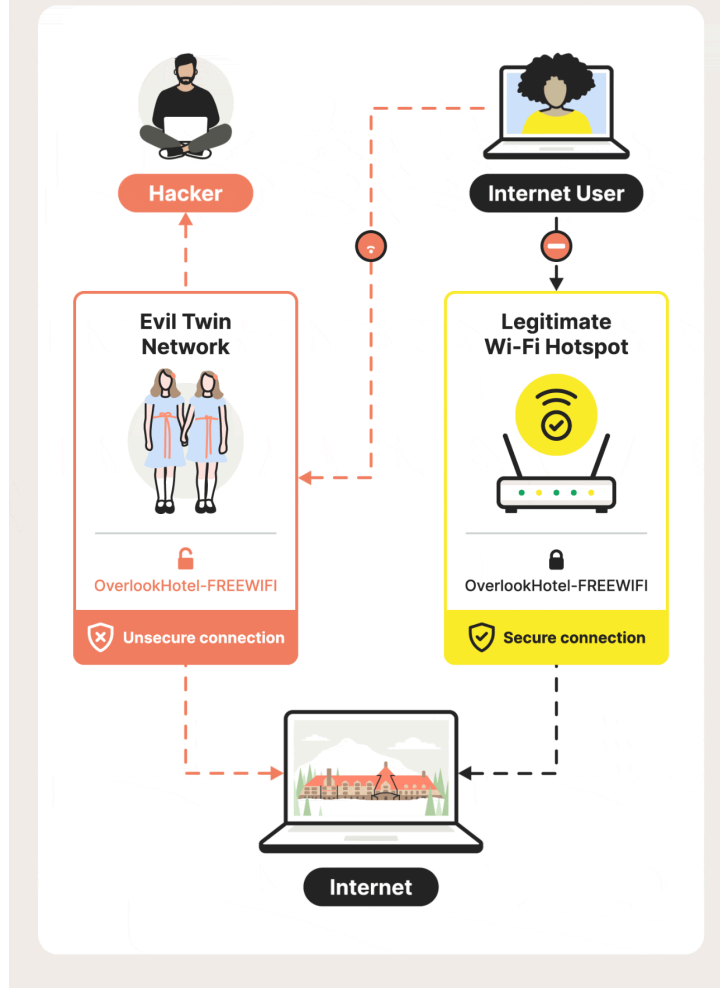
L'efficacia dello Scenario C si basa sul fatto che la *Security* riceve un'e-mail apparentemente proveniente dal concierge del resort mentre si trova sul posto. Poiché il testo fa riferimento a elementi critici per il loro lavoro (autorizzazioni dello sceriffo locale, pass biometrici per i moli e prevenzione dei droni dei paparazzi), i guardaspalle sono spinti a cliccare immediatamente sul link per non compromettere la sicurezza fisica e la privacy dell'HVT, diventando inconsapevolmente il punto di ingresso per l'attacco informatico.

Scenario D: The Proximity & Wi-Fi Vector (Evil Twin al Gozzer Ranch)

Questo scenario introduce un vettore d'attacco fisico/ibrido di prossimità, slegato dalle difese e-mail enterprise.

Evil Twin Attacks Explained

All internet and no security can make surfing the web a risky experience.



- **Meccanismo d'Attacco:** Sfruttando la presenza dell'HVT e del suo entourage presso le aree comuni del *Gozzer Ranch Golf & Lake Club*, l'attaccante posiziona un dispositivo hardware di rete (es. *Wi-Fi Pineapple*) configurato per eseguire un attacco **Evil Twin**.
- **SSID Clonato:** GozzerRanch_Guest_Secure o Gozzer_Private_Marina
- **Vulnerabilità Sfruttata:** La riconnessione automatica dei dispositivi mobili dello staff o dell'HVT a reti wireless note o con nomi identici a reti legittime precedentemente salvate.
- **Esecuzione:** Il dispositivo dell'attaccante invia pacchetti di de-autenticazione per scollegare momentaneamente i target dal Wi-Fi legittimo del resort. Gli smartphone si collegano alla rete dell'attaccante. Al primo tentativo di navigazione, sui schermi compare un *Captive Portal* (pagina di accesso) che richiede la convalida tramite account Google o iCloud per "ragioni di sicurezza e verifica degli ospiti della struttura ricettiva", esfiltrando le credenziali in chiaro.

7. Debriefing e Analisi Critica

7.1 Analisi della Credibilità (Perché le vittime abboccano?)

Nel contesto specifico di un High-Value Target (HVT) del calibro di Kim Kardashian, l'efficacia delle esche si basa sulla perfetta aderenza alla realtà operativa dei bersagli intermedi:

- **Fattore Urgenza e "Time-Window" (Scenario Stylist):** L'e-mail indirizzata a Danielle Levi non è generica; si inserisce nella finestra temporale critica di un grande evento. Nel dietro le quinte della moda di alto livello, i cambi di look dell'ultimo minuto decisi dai Direttori Creativi sono la norma. La stylist opera in uno stato di costante stress da prestazione: la paura di un fallimento d'immagine pubblico mitiga la cautela tecnica.
- **Pressione Finanziaria e Operativa (Scenario Staff Domestico):** Il personale logistico gestisce ritmi frenetici legati alle routine dei bambini. Un'e-mail che minaccia il blocco dello stipendio (payroll failure) a causa di un errore burocratico crea un picco di ansia immediato, spingendo la vittima ad agire d'impulso direttamente dallo smartphone mentre esegue altre mansioni.
- **Fattore di Geolocalizzazione (Scenario C e D):** L'esca del Gozzer Ranch è efficace perché è legata al contesto fisico immediato della vittima. Se l'HVT si trova effettivamente a Coeur d'Alene, la ricezione di una mail o il rilevamento di una rete che cita la sicurezza locale, la gestione dei droni e la logistica dei moli privati viene percepita come ordinaria efficienza del personale del resort per tutelare la privacy della famiglia.

7.2 Red Flags: Indicatori di Compromissione (IoC) e Anomalie

Nonostante l'elevata credibilità psicologica, l'attacco lascia tracce tecniche e logiche evidenti:

- **A. Anomalie di Dominio (Typosquatting):** I domini dei mittenti non corrispondono a quelli ufficiali. L'e-mail HR usa kjenner-management.com invece del canale interno certificato; l'e-mail di pubbliche relations usa balenciaga-press.com anziché il dominio enterprise legittimo (balenciaga.com). Un'analisi dei record MX o della data di registrazione del dominio (spesso registrato da pochi giorni) rivelerebbe l'inganno.
- **B. Richieste Atipiche e Deviazioni procedurali:** Richiedere la firma di un NDA o la visualizzazione di bozzetti segreti tramite un link WeTransfer/Zip protetto da password statica (BAL_KIM_2026) via e-mail è una grave deviazione rispetto ai portali di content management protetti (sistemi DAM o ERP tracciati) che le grandi maison di moda impongono.
- **C. Ostacolo ai Canali di Feedback:** L'invito implicito a "provare da tablet o telefono prima di chiamare l'ufficio" nello Scenario A è un tentativo deliberato dell'attaccante di scoraggiare la verifica Out-of-Band (la telefonata di controllo), isolando la vittima all'interno dell'interfaccia falsificata.

8. Conclusioni e Raccomandazioni (Remediation)

Il laboratorio evidenzia come la sicurezza di un High-Value Target non possa limitarsi al solo perimetro tecnologico aziendale centralizzato. Quando le difese infrastrutturali principali sono mature, il fattore umano, la supply chain e le relazioni interpersonali diventano il vettore primario d'attacco.

Per mitigare le minacce emerse nella modellazione, si raccomanda l'adozione delle seguenti contromisure strutturate su tre livelli:

8.1 Contromisure Tecniche Immediate ed Enterprise

1. **Bonifica DNS e DMARC Enforcement:** Configurare immediatamente il record DMARC del dominio drinkupdate.com impostando la direttiva su p=reject; pct=100. Questo azzerava la possibilità di attacchi di spoofing diretto effettuati abusando del nome del brand.
2. **Brand Protection & Typosquatting Monitoring:** Implementare un servizio di monitoraggio proattivo dei registri di domini. Qualsiasi registrazione di domini contenenti keyword sensibili (es. skims, kardashian, kjenner) combinati con suffissi sospetti (-press, -hr, -management) deve attivare una procedura automatica di *Takedown* legale preventivo.
3. **Autenticazione FIDO2 Hardware per l'Entourage:** Imporre a tutto lo staff, ai dipendenti domestici, alla scorta e ai consulenti esterni di massimo livello l'adozione dell'autenticazione a due fattori basata su chiavi di sicurezza hardware (es. YubiKey). Questo standard blocca il login sulle pagine clonate, poiché la chiave crittografica riconosce l'URL contraffatto e si rifiuta di inviare il token di sblocco.
4. **Segregazione Crittografica delle Comunicazioni:** Imporre lo spostamento delle comunicazioni dello staff operativo su applicazioni di messaggistica istantanea aziendali con crittografia end-to-end (es. Signal o istanze blindate dedicate), configurando una **Safe Retention Policy** con cancellazione automatica dei messaggi dopo 7 giorni. Questo garantisce che la compromissione successiva di un dispositivo non esponga lo storico dei dati logistici o delle foto riservate.
5. **Attivazione della Modalità di Protezione Avanzata (Lockdown Mode):** Configurare i dispositivi mobili privati di Kim Kardashian e dei suoi assistenti esecutivi in modalità restrittiva permanente del sistema operativo (es. *Lockdown Mode* su iOS) per inibire l'esecuzione di script dannosi, profili di configurazione non autorizzati o allegati complessi trasmessi tramite exploit zero-click.

8.2 Contromisure Procedurali e Addestramento

- **Protocollo del Doppio Canale (Out-of-Band Verification):** Stabilire una policy rigida: qualsiasi richiesta insolita o critica (invio di link di verifica, sblocco di account, condivisione di token, cambio di itinerario) proveniente dall'entourage deve essere validata tramite un secondo canale (es. chiamata vocale cifrata o di persona), vietando l'interazione

immediata tramite link ricevuti via e-mail o chat.

- **Simulazioni d'Attacco "VIP-Centered"**: Sottoporre lo staff di supporto (Nanny, Stylist, Security Detail) a sessioni di formazione e simulazioni di phishing periodiche, focalizzate sui loro specifici flussi di lavoro (richieste di payroll urgenti, variazioni di abiti dell'ultimo minuto, modifiche logistiche di club privati).

9. Appendice

Indicatori di Compromissione (IoC)

In caso di sospetto attacco in corso, i sistemi di monitoraggio e-mail e di rete della holding aziendale (SIEM/XDR) devono verificare la presenza dei seguenti indicatori tecnici associati all'infrastruttura d'attacco simulata nel presente modello:

Tipo di Indicatore	Valore dell'Indicatore (IoC)	Descrizione / Contesto
Dominio Malevolo	kjenner-management.com	Utilizzato per lo Scenario A (Phishing Staff Domestico)
Dominio Malevolo	balenciaga-press.com	Utilizzato per lo Scenario B (Phishing Stylist)
Dominio Malevolo	gozzerranch-club.com	Utilizzato per lo Scenario C (Phishing Logistico Idaho)
Target URL Falsificato	https://portal.kjenner-management.com/login/	Pannello di Credential Harvesting (Finto portale HR)
Chiave Statica / Password	BAL_KIM_2026	Codice di sblocco utilizzato nel finto archivio .zip malevolo dello Scenario B
SSID Clonato (Rete)	GozzerRanch_Guest_Secure	Rete wireless fittizia per attacco Evil Twin (Scenario D)

SSID Clonato (Rete)	Gozzer_Private_Marina	Rete wireless fittizia per attacco Evil Twin (Scenario D)
----------------------------	-----------------------	---

9.1 Appendice

Playbook di Incident Response (IR-04) - Caso "Stylist Compromised"

Codice Incidente: IR-2026-STYL_HVT

Severità: CRITICA (Livello 1)

Obiettivo Primario: Isolare l'account compromesso della stylist, proteggere i dispositivi dell'HVT ed eliminare l'infrastruttura dell'attaccante.

Fase 1: Identificazione e Triage

1. **Convalida dell'Allarme:** Il SOC analizza i log di accesso e-mail della stylist o la segnalazione di un messaggio anomalo ricevuto dall'HVT su WhatsApp/iMessage contenente il file .zip o link protetti. Se l'accesso all'account mostra una geolocalizzazione incoerente (es. login da server hosting/VPN mentre la stylist è fisicamente nel backstage dell'evento), l'incidente viene dichiarato **Stato Critico**.
2. **Attivazione della Crisis Cell:** Viene aperta una stanza di comunicazione sicura **Out-of-Band** (chiamata di gruppo cifrata su piattaforma sicura pre-convalidata, indipendente dai sistemi e-mail della holding). Vengono convocati: CISO/Head of Security dell'HVT, l'Assistente Esecutivo (EA) e il Security Manager del brand coinvolto.
3. **Notifica d'Emergenza all'HVT:** L'Assistente Esecutivo o il Capo della Scorta contatta **verbalmente o di persona** Kim Kardashian impartendo l'istruzione tattica: *"Non toccare il dispositivo mobile, non cliccare su alcun link ricevuto da Danielle nelle ultime 2 ore, mantenere acceso il telefono (per preservare la RAM per scopi forensi) ma attivare immediatamente la Modalità Aereo se è già stato aperto un link"*.

Fase 2: Contenimento Immediato

1. **Isolamento del Vettore Compromesso (Stylist):**
 - Eseguire un *Global Sign-Out* immediato su tutte le sessioni di Microsoft 365 / Google Workspace della stylist.
 - Reimpostare la password dell'account e bloccare temporaneamente le regole di inoltro

automatico delle e-mail.

- Revocare tutti i token applicativi OAuth collegati (Slack, Dropbox, Shopify).
 - Ritirare momentaneamente lo smartphone fisico della stylist sul posto, inserendolo in una busta schermata (Gabbia di Faraday) per prevenire comandi di cancellazione remota inviati dall'attaccante.
2. **Blindatura del Dispositivo dell'HVT:**
- Forzare l'attivazione della **Lockdown Mode (iOS)** sullo smartphone dell'HVT (provoca il riavvio e blocca l'esecuzione di allegati o codice web maligno).
 - Controllare la telemetria degli account iCloud e Google Drive privati dell'HVT; rimuovere istantaneamente qualsiasi dispositivo connesso non riconosciuto e forzare il cambio password.

Fase 3: Eradicazione e Analisi Forense

1. **Analisi dell'Esca in Sandbox:** Il team di Cyber Intelligence estrae l'URL malevolo (balenciaga-press.com/...) o il file .zip ed esegue un'analisi comportamentale in un ambiente virtuale isolato per mappare l'IP del server di Comando e Controllo (C2) dell'attaccante.
2. **Takedown dell'Infrastruttura dell'Attaccante:** Il team legale invia una richiesta di **Emergency Takedown** al Registrar e all'hosting provider utilizzati per far oscurare immediatamente il dominio sosia e i server di phishing.

Fase 4: Bonifica e Ripristino

1. **Hard Reset dei Dispositivi:** Lo smartphone della stylist viene inizializzato di fabbrica e i dati vengono ripristinati da un backup precedente alla data stimata dell'infezione.
2. **Verifica Integrità Dispositivo HVT:** Viene eseguita un'analisi dei log del telefono dell'HVT (tramite tool di Mobile Verification o sistemi EDR mobile aziendali) per confermare l'assenza di comunicazioni anomale verso i server C2 individuati.
3. **Generazione Nuovi Token di Comunicazione:** Vengono rigenerati i codici di sicurezza e le chiavi delle applicazioni di messaggistica tra l'HVT e la sua cerchia ristretta per garantire l'identità e l'integrità dei messaggi futuri.

Fase 5: Attività Post-Incidente (Debriefing)

- Nelle 24-48 ore successive viene avviato un **Internal Leak Assessment** per verificare come l'attaccante sia venuto a conoscenza dei dettagli specifici dell'abito ("Look 2") e degli indirizzi e-mail privati.
- Gli IoC raccolti vengono inseriti in modo permanente nelle blocklist dei gateway e-mail di tutto l'ecosistema del brand.